Beddy 2.0 — v1 대비 변경 내역

성과보고서 별첨 · 팀 YSA · 저장소 roundycat/buddy의 docs/v2/CHANGES.md

v1(브랜치 `v1`, 커밋 `79ba316`)은 2026 강원 LRS 공유대학 AWS 해커톤에서 최유경이 참여한 원작 팀의 결과물입니다(MIT License). v2는 원작 팀원 최유경이 새 팀 YSA(대표 정하민 · 최유경·최유현·최태웅)와 함께, 2026 AI 라이프 솔루션 챌린지를 위해 v1 위에 새로 한 탐구개발입니다. 모든 항목은 `git log origin/v1..main`으로 커밋 날짜와 함께 확인할 수 있습니다(저장소를 받은 뒤 `git fetch origin v1`). 공고의 사전지원 제외 단서(기 개발된 소프트웨어에 혁신적인 기능을 추가하거나 성능을 향상시키기 위한 탐구개발)에 해당하는지 판단하실 수 있도록, 아래에 v1과 v2를 항목별로 나눴습니다.

탐구 질문

아이에게 안전한 AI 친구를 만들려면, v1의 안전·프라이버시 장치는 실제로 얼마나 작동하는가? 어디까지 높일 수 있는가?

v1을 점검해 보니 이런 점이 드러났습니다.

- 위기 감지는 정규식 26개였습니다. 돌려 말한 위험 표현을 대부분 놓쳤고, "자살골", "죽고 싶을 만큼 웃겼어" 같은 일상 표현에는 보호자 '긴급' 알림을 보냈습니다.
- 학대 노출을 따로 다루지 않았습니다.
- 만 14세 미만 법정대리인 동의를 아이 본인이 체크했습니다.
- 보호자 화면으로 가는 글의 원문 유출을 검사하는 장치가 약했습니다.

변경 항목

#	영역	v1	v2
1	위기 신호 단계	3단계(없음·위험·긴급)	5단계(없음·관찰·위험·긴급·보호). 관찰은 보호자 알림 없이 기록만 하고, 보호는 학대 노출 시 보호자 자동 알림을 막습니다. 누군가에게 다쳤다는 말과 죽음 소망이 함께 있으면(같은 메시지든, 직전 대화든, 최근 3일 안이든) 긴급도 (119·109·간호사)는 유지하되 보호자에게는 알리지 않고 병원 사회복지 ·112·1388로 안내합니다
2	위기 감지	정규식 26개	정규화(초성·숫자 끼우기·띄어쓰기·오타) + 범주별 신호 8종(직접·간접·무망감·치료 거부·수단·학대·과거·외로움) + 오탐 억제 10종(과장·게임·교육·부정문·제3자·사과 초성·병원 단어 등)
3	대화 맥락	한 문장만 봄	직전 3개 메시지로 상향(무망감 뒤 "다 그만하고 싶어", 죽음 소망 뒤 장소 질문)과 하향(숙제·게임 이야기)
4	애매한 문장	없음	응답이 스트리밍되는 동안 LLM이 다시 판정합니다. 상향만 합니다. 답이 끝난 뒤 1.5초까지, 시작부터는 최소 3초를 기다리고, 그보다 늦은 판정은 버립니다 (아이가 보지 못한 알림은 보내지 않기 위해). 관리자 평가도 최소 3초로 잽니다. 재판정은 단계를 올리기만 하므로 관리자 평가의 감지율은 실서비스의 하한이고, 오경보율은 실서비스보다 낮게 나올 수 있습니다
5	아이에게 보이는 안내	단계와 무관한 고정 문구	단계별 안내. 보호자에게 무엇을 알렸는지 아이에게 투명하게 표시하고, 비밀 약속은 하지 않습니다
6	보호자 알림	고정 문구	사실만 알리고 대처 안내(의료진·109·119)를 붙입니다. 대화 원문은 보내지 않습니다
7	반복 신호	없음	72시간 안에 관찰 신호가 3번 이상이면 "보호자에게 알려도 될까?"라고 아이에게 묻습니다(아이 동의 기반 공유)
8	건강한 관계	없음	프롬프트 원칙, 응답 가드(독점·보호자 비밀 강요·"엄마보다 내가 더 잘 알아"처럼 곁의 사람보다 AI를 앞세우는 말·연애·'나는 사람' 문장 제거), 사용 리듬(늦은 밤·긴 대화), 하루 1개 사람 연결 미션
9	AI 고지	없음	대화창 'AI 친구' 표시와 상시 안내. AI가 만든 그림에는 'AI로 그렸어요'를 표시합니다(인공지능기본법 투명성 의무). 그림 모델 없이 준비된 크레용 그림을 쓸 때는 붙이지 않습니다

#	영역	v1	v2
10	비용·남용	없음	하루 AI 호출·그림 상한(넘으면 비용 0의 오프라인 답변·번들 그림), 아이 1명당 대화 속도 제한(10분 40번, 하루 200번), 메시지 1000자 제한, 로그인 실패(같은 곳·같은 이메일 10번에 10분 대기)·가입(한 곳에서 한 시간 20개) 제한. 접속 주소는 Render에서는 Cloudflare가 붙인 값(`TRUST_CF_CONNECTING_IP=1`)으로, 그 밖(AWS CloudFront 등)에서는 프록시가 덧붙인 X-Forwarded-For의 오른쪽 값으로 읽어 클라이언트가 바꿀 수 없습니다
11	배포	해커톤 계정(현재 중단)	AWS: CloudShell 한 번 실행으로 재현되는 배포. CloudFront HTTPS, 서버는 CloudFront 접근만 허용, IMDSv2·암호화. AWS 없이: 18번
12	보안 정리	문서에 데모 비밀번호 공개	삭제. 배포 때 새 비밀번호를 SSM SecureString으로 생성합니다
13	평가 체계	없음	라벨 기준서, 개발셋과 독립 평가셋 분리, `npm run eval:safety`로 v1·v2 비교
14	보호자 질문 답변(RAG) 최신성	요약을 S3에 쓰기만 하고 KB 색인을 시작하지 않음 → 처음 색인된 문서만 검색	새벽 배치 뒤 새 요약이 있으면 KB 재색인 시작
15	접근성	글자 입력만 가능	음성으로 말하기(브라우저 음성 인식), 베디 답장 소리로 듣기. 손이 불편한 아이·저학년·시력이 약한 아이
16	측정 경로	—	배포된 서비스에서 규칙만 / 규칙+LLM 판정 지표를 내는 관리자 경로(`/api/admin/safety-eval`, `deploy/aws/run-eval.sh`)
17	응답 안전 필터	Bedrock Guardrails에만 의존. 앱 자체의 응답 검사는 없음	문장 단위 출력 필터를 아이에게 보이는 모든 AI 글에 적용합니다(미션 계획 Agent의 설명이 화면 문구로 쓰일 때 포함). 개인정보(전화·이메일·주민번호 형식)는 가리고, 약 복용·중단 지시("두 알 더" 같은 말로 센 양 포함)와 위험 방법 표현, 관계 규칙 위반 문장은 바꿉니다. 비밀 약속("너랑 나만의 비밀", "아무한테도 말 안 할게")에는 위험하면 어른에게 알려야 할 때가 있다는 문장으로 답합니다. 문장이 화면에 나가기 **전에** 검사하고, 문장 끝 없이 길게 이어지면 앞부분과 합쳐 판단합니다. 대화뿐 아니라 이야기·모험 미션·소원 아이디어·성장 일기·이야기책 같은 다른 아이용 AI 글에도 적용합니다
18	AWS 없이 배포	AWS 전용	Render + Claude API 배포(`render.yaml`, `deploy/render/README.md`). 계정은 디스크의 bcrypt 해시 파일로, 보호자 질문 검색은 서버 안 요약 검색으로, 새벽 배치는 서버 안 스케줄러로 대신합니다. 심사·시연 계정은 환경 변수 비밀번호로 시작할 때 만듭니다
19	Claude API 연동	없음	Claude Haiku 5.5 공급자. 용도별 effort·thinking, 재시도, 스트림 정지 감시. 모델이 거절하면 아이에게 안전한 안내 문장을 보여 주고, 그 대화는 다음 대화와 새벽 배치에 다시 보내지 않습니다(계속 거절되는 것을 막기 위해). 안전 재판정이 거절되면 '관찰'로 기록합니다
20	미션 생성 장애	LLM 답에 JSON이 없으면 오류가 위로 올라가 미션 화면과 보호자 리포트까지 실패	생성 실패는 규칙 기반 미션으로 대체
21	날짜 기준	서버가 UTC라 하루가 오전 9시(KST)에 바뀌고, 05:00 새벽 배치가 전날 날짜로 돎	컨테이너 시간대를 Asia/Seoul로 고정
22	로컬 저장 안정성	파일을 통째로 덮어써 쓰는 도중 꺼지면 깨질 수 있음. 같은 파일을 여는 두 저장소(`memory-post.json`)가 서로의 쓰기를 덮어씀	임시 파일에 쓴 뒤 교체, 파일당 메모리 맵 하나를 공유, 종료 신호 때 남은 쓰기 저장

#	영역	v1	v2
23	법정대리인 동의 확인	아이가 "(필수) 보호자 동의를 받았어요"를 직접 체크	만 14세 미만은 연결된 보호자 계정이 동의해야 AI·데이터 기능이 열립니다(개인정보보호법 제22조의2). 대화뿐 아니라 날씨(위치)·미션·기억·정원·지갑 등 아이용 API와 화면 전체에 적용하고, 동의 기록이 없는 아이 계정도 동의부터 받습니다. 동의 기록(관계·이름·항목·문안 버전·시각)을 남기고, 연결된 보호자라면 누구든 철회할 수 있습니다(철회하면 모든 보호자의 동의가 끝나고 기록을 파기). 계정을 지운 뒤 다른 기기에 남은 로그인은 더 이상 통하지 않습니다. 만 14세 이상은 개인정보와 민감정보 동의를 따로 받습니다(제23조). 한계: 시제품은 아이 기기에 뜬 초대 코드로 연결된 보호자 계정이 관계·이름을 적고 동의합니다. 실제 서비스에서는 휴대전화 본인인증 같은 시행령 제17조의2 제1항의 확인 방법을 붙여야 합니다
24	아이 선택 공유	보호자 화면에 정해진 항목이 그대로 나감	아이가 범주별로 보호자와 나눌지 고릅니다. 보호자 화면은 아이의 선택과 보호자 보기 설정을 모두 따릅니다. 무엇이 보호자에게 가는지는 공유 정책 한 곳에서 정합니다
25	보호자 글 유출 검사	대화 기록 형식("아이: …" 여러 줄)과 좌표만 막음	보호자에게 가는 글(오늘의 메시지·공감 가이드·질문 답변·KB 요약·관심 알림)에 아이 원문, 인용, 비밀이라고 한 내용, 제3자 실명, 병실 호수가 들어가는지 검사합니다. 걸리면 안전한 문장으로 바꿉니다. 검사 기준에는 대화 외에 소원, 그림일기 글, 사진 설명, 모험 기록, 설문의 '기타' 답까지 넣었고, 보호자 질문용 요약 문서에는 소원 원문 대신 소원 종류만, 성향·취미는 앱의 보기 라벨만 씁니다
26	반복 신호 공유 동의	없음	7번을 대화 경로에 연결했습니다. 관찰 신호가 72시간에 3번 쌓이면, 패턴만 담은 문장("요즘 외롭다고 느끼는 때가 자주 있어 보여요")을 아이에게 먼저 보여 주고 동의를 받은 뒤에만 보호자에게 보냅니다
27	데모 계정	비밀번호가 코드·문서에 그대로 있음	저장소에서 삭제. 심사·시연 계정은 서버가 시작할 때 환경 변수 비밀번호로 만들고, 만 14세 미만 아이와 보호자 동의 기록까지 갖춥니다. 심사 계정은 심사위원마다 한 쌍씩 쓰도록 다섯 쌍(judge1~5)을 두고, 매일 새벽 배치가 처음 상태로 되돌립니다(앞사람의 위기 문장·공유 설정·동의 철회가 다음 사람 화면을 바꾸지 않게)
28	보호자 알림의 견고성	알림·신호 기록·대화 저장이 답이 다 흘러간 뒤에만 실행 → 아이가 위기 문장을 보내고 바로 앱을 닫으면 아무것도 남지 않음	위기 판정이 끝나면 답을 흘려보내기 전에 알림과 신호 기록을 시작합니다. 대화는 아이가 중간에 나가도 저장하고, 도움 패널을 보기 전에 나갔다면 무엇을 알렸는지 저장된 답에 적어 둡니다. 확인하지 않은 '긴급' 알림은 더 약한 알림으로 덮어쓰지 않습니다
29	보관 기간 지키기	대략적 위치를 읽을 때만 만료 확인(다시 오지 않으면 계속 남음). 새벽 배치가 도중에 끊기면 그날 다시 돌지 않음	새벽 배치에서 7일 지난 위치를 지웁니다. '시작'에 2시간 넘게 머문 배치는 다시 돌립니다. 동의 철회로 기록을 지운 뒤에는 그 사이 흐르던 대화를 저장하지 않습니다. 보호자가 탈퇴하면 동의 기록에서 이름을 지웁니다
30	화면 문구	이름 뒤 조사가 받침과 맞지 않음("지민와", "지민는"), 아이 화면에 합니다체·'당신'·개발자 메모·내부 오류 원인이 섞임, 기온을 모를 때 0°로 표시	이름·감정·일정 이름 뒤 조사를 받침에 맞춤. 아이 화면은 친구 말투(반말)와 안내 말투(해요체)로 정리하고, 개발자 메모와 오류 원인은 화면에서 뺌. 기온을 모르면 표시하지 않음. 문구 교정 보고서의 60개 항목을 고쳤습니다
31	학대·폭력 대화의 뒤처리	구분 없음	아이가 누군가에게 다치거나 위협받았다고 말한 대화와 그 뒤 72시간의 대화는 아이 화면과 대화 맥락에는 남기되, 기억 학습·감정 기록·새벽 기억 통합·감정 정리에서 뺍니다. 이 기록들이 보호자 요약과 질문 답변의 재료이기 때문입니다(보호자 자동 알림만 막던 것을 끝까지 막음)
32	일상 '때리다·맞다' 오탐	—	"동생이 모기 때려잡았어", "베개싸움 했어ㅋㅋ", "엄마 말이 또 맞았어", "옷이 딱 맞아"가 보호 경로로 가던 것을 고침(물건을 때림, 놀이, '맞다'가 '옳다·맞춤'인 경우). 아프다·자꾸·나를 때렸다 같은 말이 있으면 그대로 보호 경로입니다. 직접 만든 문장으로만 맞췄고 평가셋 문장은 보지 않았습니다
0	저장소 정리	의존성 잠금 파일 불일치(`npm ci` 실패)	잠금 파일 동기화

측정

지표	v1	v2	근거
(개발셋 180문장) 위험·긴급 감지율	24.7%	100%	`eval/results/crisis-dev.md` — 규칙 개발에 쓴 문장이라 공식 수치가 아닙니다
(개발셋) 일반 대화 보호자 오경보율	25.4%	0%	같은 출처
(독립 일상 170문장) 보호자 오경보율	8.2% (14/170)	3.5% (6/170)	`eval/results/crisis-crisis-none.md` — 규칙을 보지 않은 별도 과정에서 AI로 합성한 문장. v2는 규칙 계층, 측정 커밋 `60c4d3d`
(독립 일상 170문장) 어떤 신호든 붙은 비율	8.2%	5.3% (9/170)	같은 출처. 1건은 아이 화면에 보호 경로를 잘못 안내(처음 측정 때 4.7%였고, 이후 폭력 노출 규칙을 더하며 늘었음)
(독립 유출 150문장) 보호자 글 유출 탐지율 (유출 75건·5유형)	0% (0/75)	72.0% (54/75)	`eval/results/leak-leak-test.md` — 유형별: 원문 88.0%, 인용 86.7%, 위치 80.0%, 제3자 실명 80.0%, 비밀 20.0%
(독립 유출 150문장) 정상 요약 오탐률	0%	4.0% (3/75)	같은 출처. 정밀도 94.7%
(독립 위기 문장) 위험·긴급 감지율 등	측정 예정	측정 예정	팀원 4명이 규칙을 보지 않고 쓰는 140문장 (`docs/contest/heldout-risk-writing.md`)

유출 검사는 '비밀이라고 한 내용'을 바꿔 말한 경우를 잘 잡지 못합니다(20%). 이 결과를 본 뒤에 같은 평가셋으로 규칙을 고치면 독립성이 깨지므로, 개선은 새 평가셋으로 검증합니다.

표의 v2 값은 규칙 계층만 잰 것입니다. 실서비스에서는 애매한 문장을 LLM이 다시 판정하는데, 단계를 올리기만 하므로 실서비스 오경보율은 이 값보다 높을 수 있습니다(배포 주소에서 `/api/admin/safety-eval`로 규칙+LLM 값을 잽니다).